

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

CYBERSECURITY INCIDENT RESPONSE

Playbook di risposta agli incidenti cyber — NIS2 + ISO 27001 A.5.24-26 + NIST CSF

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO086_00	00	04/05/2026	5
Redatto da	Approvato da	Classificazione	Stato
IT Manager / DPO / RSGI	AD – Francesco Epifani	Riservato (distribuzione limitata al CSIRT interno)	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
04/05/2026	04/05/2026	04/05/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito

La presente procedura definisce il processo di Incident Response (IR) per gli incidenti di cybersecurity in Toscana Diagnostica, in coerenza con NIS2 (D.Lgs. 138/2024), il framework ISO 27001:2022 (controlli A.5.24, A.5.25, A.5.26, A.5.27, A.5.28), il NIST CSF 2.0 (funzioni Detect e Respond) e gli obblighi di notifica all'ACN. Si applica a qualsiasi incidente che comprometta confidenzialità, integrità o disponibilità di informazioni o sistemi IT/OT aziendali, inclusi LIS, GIPOnext, sistemi di refertazione, infrastrutture cloud e di rete.

2. Riferimenti normativi e framework

Riferimento	Pertinenza
NIS2 — D.Lgs. 138/2024	Notifica ad ACN entro 24h (early warning) e 72h (notifica formale)
ISO 27001:2022 Annex A controlli A.5.24-A.5.28	Pianificazione, segnalazione, valutazione, risposta a eventi/incidenti, apprendimento
NIST CSF 2.0	Framework Detect/Respond/Recover
NIST SP 800-61 Rev.2	Computer Security Incident Handling Guide
Reg. UE 2016/679 (GDPR)	Notifica data breach al Garante Privacy entro 72h
IDL026 / MOD181-184	Procedure operative NIS2 specifiche

3. Definizioni

Termine	Definizione
Evento cyber	Occorrenza identificata di una possibile violazione delle policy di sicurezza
Incidente cyber	Evento confermato che compromette CIA (Confidenzialità, Integrità, Disponibilità)
Incidente significativo (NIS2)	Incidente con impatto rilevante secondo i criteri del Reg. UE 2024/2690
CSIRT interno	Computer Security Incident Response Team (IT Manager + DPO + RSGI + DT Lab)
IoC	Indicator of Compromise (hash file, IP, dominio, comando)
Playbook	Procedura strutturata per gestire uno scenario specifico di incidente
Containment	Limitazione della diffusione/impatto dell'incidente
Eradication	Rimozione della causa dell'incidente
Recovery	Ripristino delle operazioni normali

4. Composizione del CSIRT interno

Ruolo	Funzione	Responsabilità nella risposta
Incident Manager	IT Manager	Coordinamento risposta, decisioni operative, comunicazione interna
Privacy Lead	DPO	Valutazione data breach, notifica Garante, comunicazione interessati
NIS2 Lead	RSGI / IT Manager	Notifica ACN, gestione MOD181/184
Operations Lead	DT Lab / Business Lead	Continuità operativa, attivazione fallback
Forensic Technical Lead	IT Manager + fornitore esterno SOC	Analisi tecnica, IoC, evidenze

Comms Lead	AD + responsabile comunicazione	Comunicazione esterna, gestione media
Legal Lead	Studio legale convenzionato	Profili legali, denuncia Polizia Postale se applicabile

5. Fasi del processo IR

Fase	Attività principali	SLA
1. Preparation	Asset inventory, baseline, playbook aggiornati, drill, formazione team CSIRT	Continuo
2. Detection & Analysis	Rilevamento eventi (SIEM, EDR, segnalazioni), triage, classificazione (low/medium/high/critical), apertura ticket	< 1 h da rilevamento
3. Containment	Isolamento sistemi compromessi, blocco account, segregazione rete, preservazione evidenze	< 4 h da classificazione
4. Eradication	Rimozione malware, patch vulnerabilità, reset credenziali, hardening	< 48 h da containment
5. Recovery	Ripristino sistemi da backup verificati, monitoraggio rinforzato, return to operations	< 72 h da eradication
6. Post-Incident	Lessons learned, aggiornamento playbook, comunicazione finale, chiusura ticket	< 30 gg da recovery

6. Playbook per scenari principali

6.1 Playbook Ransomware

- Detection: alert EDR di crittografia massiva file, alert backup integrity, alert utente.
- Containment: isolamento immediato del/dei sistemi infetti dalla rete; blocco account compromessi; revoca certificati se applicabile.
- Eradication: imaging forense del sistema infetto; ricerca IoC sugli altri sistemi; rimozione malware con strumenti specifici.
- Recovery: ripristino da backup offline verificati come puliti; password reset di tutti gli account a privilegi elevati; monitoraggio rinforzato 30gg.
- Comunicazione: notifica ACN (NIS2) entro 24h; eventuale notifica Garante (GDPR) se data breach personale; comunicazione clienti se SLA impattati.
- Legale: NON pagare il riscatto (decisione AD + Legal); valutare denuncia Polizia Postale.

6.2 Playbook Data Exfiltration

- Detection: anomalia traffico rete in uscita, alert DLP, segnalazione esterna.
- Containment: blocco egress traffic verso destinazioni sospette; revoca accessi degli account coinvolti.
- Eradication: identificazione vettore (phishing, vulnerability, insider); patching/reset; revoca chiavi API.
- Recovery: hardening sistemi esposti; review accessi; rotazione segreti.
- Comunicazione: GDPR data breach (Garante 72h); comunicazione interessati se rischio elevato; ACN se rilevanza NIS2.

6.3 Playbook Account Compromise

- Detection: login da geolocalizzazione anomala, MFA fallito ripetutamente, attività insolita su account.
- Containment: blocco immediato account; reset credenziali; revoca sessioni attive.
- Eradication: analisi attività compiute con account; verifica privilege escalation; controllo azioni sui dati.
- Recovery: re-provisioning account con MFA rinforzato; review log delle attività.
- Comunicazione: variabile in base a impatto.

6.4 Playbook DDoS

- Detection: spike di traffico verso il sito web/portale paziente, segnalazione ISP.
- Containment: attivazione protezione DDoS provider (Cloudflare/Akamai); rate limiting; blocco IP origine.
- Recovery: ripristino servizi normali, monitoraggio prolungato.
- Comunicazione: clienti se downtime > 30 min; eventuale ACN se NIS2.

6.5 Playbook Supply Chain Attack

- Detection: vulnerabilità annunciata in software/SaaS in uso; IoC distribuiti da CERT.
- Containment: isolamento del componente compromesso; switch a alternativa se possibile.
- Eradication: collaborazione con vendor; patch o rimozione; verifica IoC su tutti i sistemi.
- Recovery: ripristino con componente patchato; revisione contratti SLA con vendor.
- Comunicazione: ACN (se NIS2); inventario fornitori ICT (MOD182) aggiornato.

7. Notifiche obbligatorie

Destinatario	Trigger	Tempistica	Modalità	Riferimento
ACN (NIS2)	Incidente significativo	Early warning entro 24h; notifica entro 72h	Portale ACN	IDL026 + MOD184
Garante Privacy (GDPR)	Data breach con rischio interessati	Entro 72h da conoscenza	Portale GPDP	PRO005 Privacy
Interessati (GDPR)	Data breach ad alto rischio	Senza ingiustificato ritardo	Email/PEC/lettera	PRO005 Privacy
Polizia Postale	Reato cyber	Tempo zero (denuncia opportuna)	Diretta telematica o	Legal Lead
Clienti B2B impattati	SLA violato o impatto sui dati cliente	Entro 24h dal containment	Email + telefono	PRO017 contratti fornitura
CdA + OdV	Incidente	Entro 24h	Comunicazione	OdV (MOD222)

	significativo		ufficiale	
--	---------------	--	-----------	--

8. KPI di Incident Response

KPI	Target	Frequenza
MTTD (Mean Time To Detect)	< 4 h per High/Critical	Continua
MTTR (Mean Time To Respond)	< 8 h per High/Critical	Continua
Tempo di notifica ACN	< 24 h da classificazione	Per incidente
Tempo di notifica Garante	< 72 h	Per incidente
% incidenti con lessons learned implementate < 30gg	> 90 %	Trimestrale
Numero drill IR / anno	≥ 2	Annuale
% personale CSIRT formato (annual training)	100 %	Annuale
Cyber maturity assessment (NIST CSF)	Da Tier 2 (Risk Informed) a Tier 3 (Repeatable) entro 2027	Annuale

9. Riferimenti documentali

Codice	Documento
TD-SGI-REG016	Statement of Applicability ISO 27001
TD-SGI-PRO109	Information Security Policy
TD-SGI-PRO070	Adeguamento NIS2
TD-SGI-PRO094	Vulnerability Management
TD-SGI-PLN013	Business Continuity Plan
TD-SGI-PLN014	Disaster Recovery Plan
TD-SGI-IDL026	Trasmissione notifiche al Portale ACN
TD-SGI-MOD181	Registro Incidenti Significativi NIS2
TD-SGI-MOD182	Inventario Fornitori ICT
TD-SGI-MOD183	Verbale Tabletop NIS2
TD-SGI-MOD184	Checklist Notifiche NIS2
TD-SGI-MOD200	Designazione Punto di Contatto NIS
TD-SGI-PRO075	BCP-Lab
TD-SGI-PRO090	Comunicazione di Crisi

10. Storico delle revisioni

Rev.	Data	Descrizione	Approvazione
00	04/05/2026	Prima emissione: CSIRT, 6 fasi IR, 5 playbook (ransomware, exfiltration, account, DDoS, supply chain), notifiche e KPI.	AD / IT / DPO